

User Authentication

Contents

- 1 User Authentication
- 2 Password-Based Authentication
- 3 Storing Passwords
- 4 Selecting Passwords
- 5 Token-Based Authentication
- 6 Biometric Authentication
- 7 Summary

The process of verifying a claim that a system entity or system resource has a certain attribute value.

— R. Shirey, “Internet Security Glossary, Version 2”, IETF RFC4949

Two Steps of Authentication

- 1 **Identification step**: presenting an identifier to the security system
 - E.g. user ID
 - Generally unique but not secret

Two Steps of Authentication

- ① **Identification step**: presenting an identifier to the security system
 - E.g. user ID
 - Generally unique but not secret
- ② **Verification step**: presenting or generating authentication information that acts as evidence to prove the binding between the attribute and that for which it is claimed.
 - E.g. password, PIN, biometric information
 - Often secret or cannot be generated by others

User authentication is primary line of defence in computer security;
other security controls rely on user authentication

Means of Authentication

Something the individual ...

Knows

- E.g. password, PIN, question answers

Means of Authentication

Something the individual ...

Knows

- E.g. password, PIN, question answers

Possesses

- Token, e.g. keycards, smart card, physical key

Means of Authentication

Something the individual ...

Knows

- E.g. password, PIN, question answers

Possesses

- Token, e.g. keycards, smart card, physical key

Is

- Static biometrics, e.g. fingerprint, retina, face

Means of Authentication

Something the individual ...

Knows

- E.g. password, PIN, question answers

Possesses

- Token, e.g. keycards, smart card, physical key

Is

- Static biometrics, e.g. fingerprint, retina, face

Does

- Dynamic biometrics, e.g. voice pattern, handwriting, typing rhythm

Humans are also large, expensive to maintain, difficult to manage and they pollute the environment. It is astonishing that these devices continue to be manufactured and deployed. But they are sufficiently pervasive that we must design our protocols around their limitations.

— Kaufman, Perlman, Speciner “Network Security: Private Communication in a Public World”, Prentice Hall 2002

Contents

- 1 User Authentication
- 2 Password-Based Authentication**
- 3 Storing Passwords
- 4 Selecting Passwords
- 5 Token-Based Authentication
- 6 Biometric Authentication
- 7 Summary

Password-Based Authentication

- Many multiuser computer systems used combination of ID and password for user authentication
- System initially stores username and password
- User submits username/password to system; compared against stored values; if match, user is authenticated

Password-Based Authentication

- Many multiuser computer systems used combination of ID and password for user authentication
- System initially stores username and password
- User submits username/password to system; compared against stored values; if match, user is authenticated
- Identity (ID):
 - Determines whether user is authorised to gain access to system
 - Determines privileges of user, e.g. normal or superuser
 - Used in access control to grant permissions to resources for user

Password-Based Authentication

- Many multiuser computer systems used combination of ID and password for user authentication
- System initially stores username and password
- User submits username/password to system; compared against stored values; if match, user is authenticated
- Identity (ID):
 - Determines whether user is authorised to gain access to system
 - Determines privileges of user, e.g. normal or superuser
 - Used in access control to grant permissions to resources for user
- Password:
 - What is a good password?
 - How to store the passwords?
 - How to submit the passwords?
 - How to respond (if no match)?

Vulnerability of Passwords

- Offline Dictionary Attack** Attacker obtains access to ID/password (hash) database; use dictionary to find passwords
- Countermeasures: control access to database; reissue passwords if compromised; strong hashes and salts

Vulnerability of Passwords

- Offline Dictionary Attack** Attacker obtains access to ID/password (hash) database; use dictionary to find passwords
- Countermeasures: control access to database; reissue passwords if compromised; strong hashes and salts
- Specific Account Attack** Attacker submits password guesses on specific account
- Countermeasure: lock account after too many failed attempts

Vulnerability of Passwords

- Offline Dictionary Attack** Attacker obtains access to ID/password (hash) database; use dictionary to find passwords
- Countermeasures: control access to database; reissue passwords if compromised; strong hashes and salts
- Specific Account Attack** Attacker submits password guesses on specific account
- Countermeasure: lock account after too many failed attempts
- Popular Password Attack** Try popular password with many IDs
- Countermeasures: control password selection; block computers that make multiple attempts

Vulnerability of Passwords

Password Guessing Against Single User Gain knowledge about user and use that to guess password

- Countermeasures: control password selection; train users in password selection

Vulnerability of Passwords

Password Guessing Against Single User Gain knowledge about user and use that to guess password

- Countermeasures: control password selection; train users in password selection

Computer Hijacking Attackers gains access to computer that user currently logged in to

- Countermeasure: auto-logout

Vulnerability of Passwords

Password Guessing Against Single User Gain knowledge about user and use that to guess password

- Countermeasures: control password selection; train users in password selection

Computer Hijacking Attackers gains access to computer that user currently logged in to

- Countermeasure: auto-logout

Exploiting User Mistakes Users write down password, share with friends, tricked into revealing passwords, use pre-configured passwords

- Countermeasures: user training, passwords plus other authentication

Vulnerability of Passwords

Exploiting Multiple Password Use Passwords re-used across different systems/accounts, make easier for attacker to access resources once one password discovered

- Countermeasure: control selection of passwords on multiple account/devices

Electronic Monitoring Attacker intercepts passwords sent across network

- Countermeasure: encrypt communications that send passwords

Contents

- 1 User Authentication
- 2 Password-Based Authentication
- 3 Storing Passwords
- 4 Selecting Passwords
- 5 Token-Based Authentication
- 6 Biometric Authentication
- 7 Summary

Storing Passwords

- Upon initial usage, user ID and password are registered with system
- ID, password (or information based on it), and optionally other user information stored on system, e.g. in file or database
- To access system, user submits ID and password, compared against stored values
- How should passwords be stored?

Storing Passwords in the Clear

$$ID, P$$

Insider attack: normal user reads the database and learns other users passwords

- Countermeasure: access control on password database

Storing Passwords in the Clear

$$ID, P$$

Insider attack: normal user reads the database and learns other users passwords

- Countermeasure: access control on password database

Insider attack: admin user reads the database and learns other users passwords

- Countermeasure: none—admin users must be trusted!

Storing Passwords in the Clear

$$ID, P$$

Insider attack: normal user reads the database and learns other users passwords

- Countermeasure: access control on password database

Insider attack: admin user reads the database and learns other users passwords

- Countermeasure: none—admin users must be trusted!

Outsider attack: attacker gains unauthorised access to database and learns all passwords

- Countermeasure: do not store passwords in the clear

Encrypting the Passwords

$$ID, E(K, P)$$

- Encrypted passwords are stored
- When user submits password, it is encrypted and compared to the stored value

Encrypting the Passwords

$$ID, E(K, P)$$

- Encrypted passwords are stored
- When user submits password, it is encrypted and compared to the stored value
- Drawback: Secret key, K , must be stored (on file or memory); if attacker can read database, then likely they can also read K

Hashing the Passwords

$$ID, H(P)$$

- Hashes of passwords are stored
- When user submits password, it is hashed and compared to the stored value
- Practical properties of hash functions:
 - Variable sized input; produce a fixed length, small output
 - No collisions
 - One-way function
- If attacker gains database, practically impossible to take a hash value and directly determine the original password

Brute Force Attack on Hashed Passwords

- Aim: given one (or more) target hash value, find the original password
- Start with large set of possible passwords (e.g. from dictionary, all possible n -character combinations)
- Calculate hash of possible password, compare with target hash
 - if match, original password is found
 - else, try next possible password
- Attack duration depends on size of possible password set

Pre-calculated Hashes and Rainbow Tables

- How to speed up brute force attack? Use hash values calculated by someone else
- Possible passwords and corresponding hashes stored in database
- Attacker performs lookup on database for target hash
- How big is such a database of pre-calculated hashes?
 - In raw form, generally too big to be practical (100's, 1000's of TB)
 - Using specialised data structures (e.g. Rainbow tables), can obtain manageable size, e.g. 1 TB
- Trade-off: reduce search time, but increase storage space
- Countermeasures:
 - Longer passwords
 - Slower hash algorithms
 - Salting the password before hashing

$$ID, Salt, H(P||Salt)$$

- When ID and password initially created, generate random s -bit value (**salt**), concatenate with password and then hash
- When user submits password, salt from password database is concatenated, hashed and compared
- If attacker gains database, they know the salt; same effort to find password as brute force attack
- BUT pre-calculated values (e.g. Rainbow tables) are no longer feasible
 - Space required increased by factor of 2^s

Password Storage: Best Practice

When storing user login information, always store a hash of a salted password

$$ID, Salt, H(P||Salt)$$

- Password: see next sections on password policies
- Salt: random, generated when ID/password first stored; 32 bits or longer
- Hash function: slow, adaptive speed (work factor), e.g. bcrypt/scrypt, PBKDF2

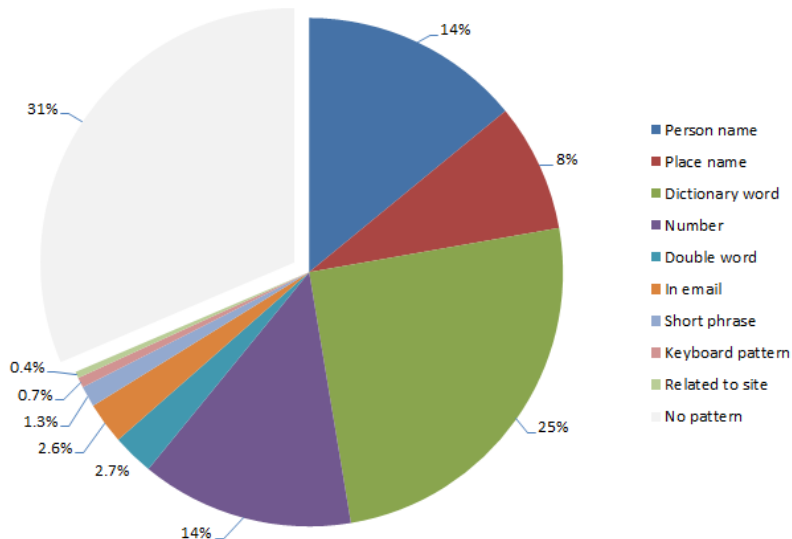
Design for failure: assume password database will eventually be compromised

Contents

- 1 User Authentication
- 2 Password-Based Authentication
- 3 Storing Passwords
- 4 Selecting Passwords
- 5 Token-Based Authentication
- 6 Biometric Authentication
- 7 Summary

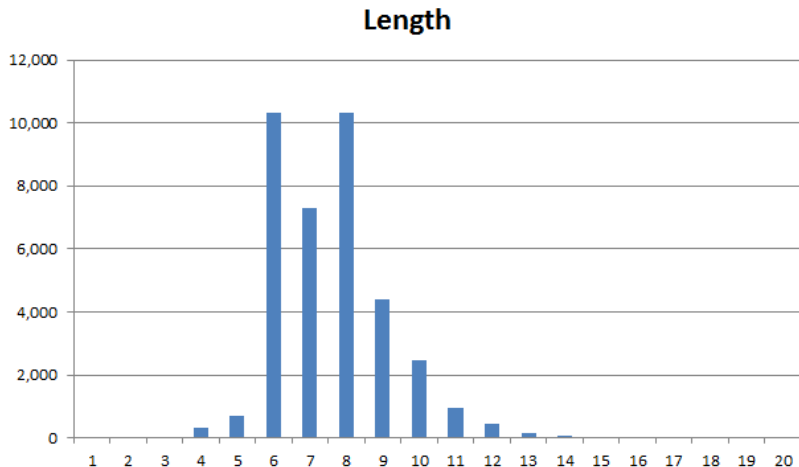
How Do People Select Passwords?

Analysis of 300,000 leaked passwords



How Long Are Passwords?

Analysis of 37,000 leaked passwords



Credit: Troy Hunt, *A brief Sony password analysis*, www.troyhunt.com, CCBY3.0

Other Common Characteristics of Passwords

- Most use only alphanumeric characters
- Most are in (password) dictionaries
- Many users re-use passwords across systems
- Some very common passwords: 123456, password, 12345678, qwerty, abc123, letmein, iloveyou, ...
- When forced to change passwords, most users change a single character

Password Selection Strategies

- User education** Ensure users are aware of importance of hard-to-guess passwords; advise users on strategies for selecting passwords
- Computer-generated passwords** Generate random or pronounceable passwords (but poorly accepted by users)
- Reactive password checking** Regularly check user's passwords, inform them if weak passwords
- Proactive password checking** Advise user on strength when selecting a password

Contents

- 1 User Authentication
- 2 Password-Based Authentication
- 3 Storing Passwords
- 4 Selecting Passwords
- 5 Token-Based Authentication**
- 6 Biometric Authentication
- 7 Summary

Token-Based Authentication

Objects that a user possesses for purpose of user authentication are called **tokens**

Card Type	Defining Feature	Example
Embossed	Raised characters only, on front	Old credit card
Magnetic stripe	Magnetic bar on back, characters on front	Bank card
Memory	Electronic memory inside	Phone card
Smart	Electronic memory & processor inside	Biometric ID
–Contact	–Electrical contacts on surface	card
–Contactless	–Radio antenna embedded inside	

Credit: Table 3.3 in Stallings and Brown, *Computer Security*, 2nd Ed., Pearson 2012

Memory Cards

- Can store but do not process data
- Most common is the magnetic stripe card
- Can include an internal electronic memory
- Can be used alone for physical access, e.g. hotel room, ATM
- Provides significantly greater security when combined with a password or PIN
- Drawbacks include
 - requires a special reader
 - loss of token
 - user dissatisfaction

- Physical characteristics:
 - include an embedded microprocessor
 - a smart token that looks like a bank card
 - can look like calculators, keys, small portable objects
- Interface:
 - manual interfaces include a keypad and display for interaction
 - electronic interfaces communicate with a compatible reader/writer
- Authentication protocol:
 - static
 - dynamic password generator
 - challenge-response

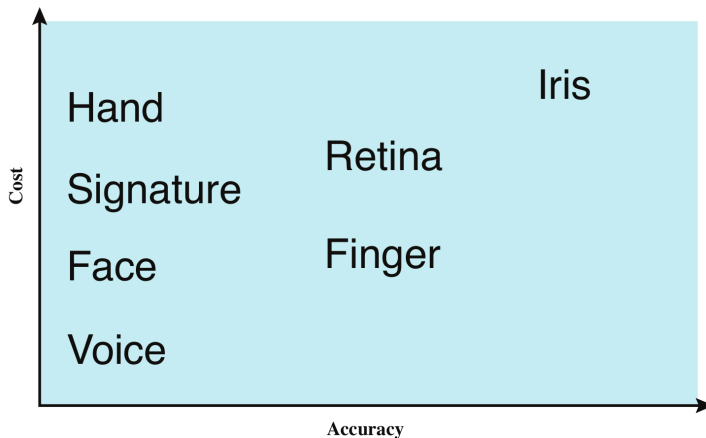
Contents

- 1 User Authentication
- 2 Password-Based Authentication
- 3 Storing Passwords
- 4 Selecting Passwords
- 5 Token-Based Authentication
- 6 Biometric Authentication**
- 7 Summary

Biometric Authentication

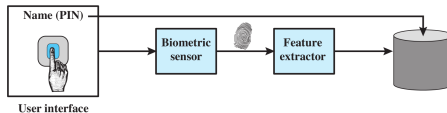
- Attempts to authenticate an individual based on unique physical characteristics
- Based on pattern recognition
- Technically complex and expensive when compared to passwords and tokens
- Physical characteristics used include:
 - facial characteristics
 - fingerprints
 - hand geometry
 - retinal pattern
 - iris
 - signature
 - voice

Cost vs Accuracy for Biometric Authentication

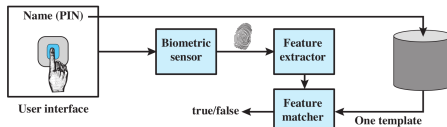


Credit: Figure 3.5 in Stallings and Brown, *Computer Security*, 2nd Ed., Pearson 2012

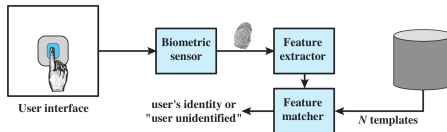
Generic Biometric System



(a) Enrollment



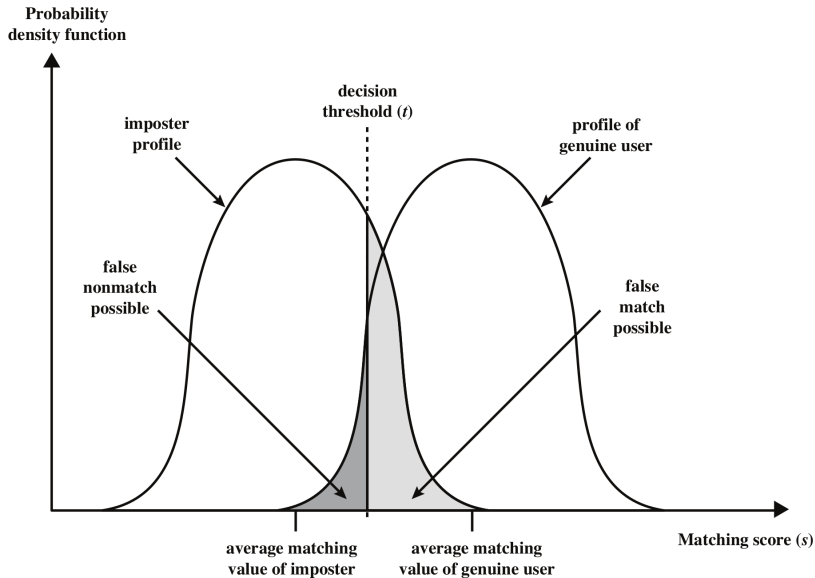
(b) Verification



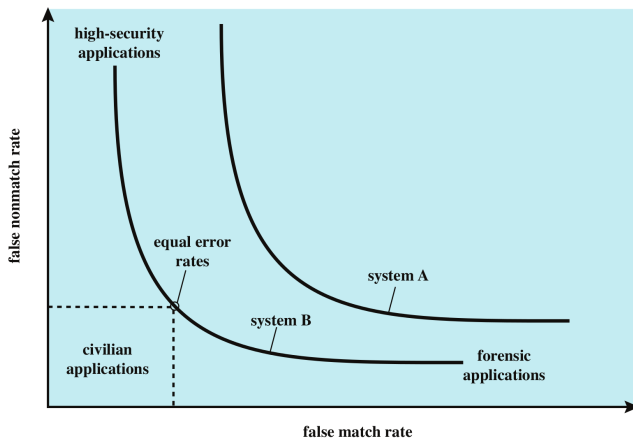
(c) Identification

Credit: Figure 3.6 in Stallings and Brown, *Computer Security*, 2nd Ed., Pearson 2012

Profiles of Imposter and Authorised User

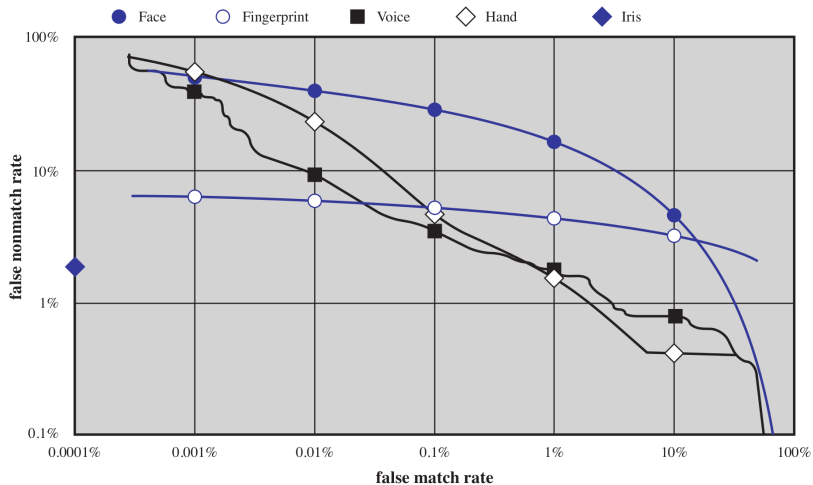


Idealised Operating Characteristics



Credit: Figure 3.8 in Stallings and Brown, *Computer Security*, 2nd Ed., Pearson 2012

Actual Operating Characteristics



Credit: Figure 3.9 in Stallings and Brown, *Computer Security*, 2nd Ed., Pearson 2012

Contents

- 1 User Authentication
- 2 Password-Based Authentication
- 3 Storing Passwords
- 4 Selecting Passwords
- 5 Token-Based Authentication
- 6 Biometric Authentication
- 7 Summary

Key Points

- User presents ID and authentication information to system; system verifies that they are authorised to access
- Authentication information:
 - What you know: passwords
 - What you possess: tokens
 - What you are or do: biometrics
- Always store a hash of a salted password
- Educate users and employ proactive password checking strategies
- Tokens and biometrics can increase security, but at extra cost and inconvenience

- Password selection and usage practices are poor for many systems
- Many vulnerabilities for user authentication techniques; multifactor authentication adds security

Areas To Explore

- Remote user authentication
- Legal, financial and ethical implications of poor design of password-based systems